TECHNICAL DETAIL

Title	Broken Access Control on Employee Management Endpoint Leads to Sensitive Data Leak & Unauthorized Write Access
Reporter	Daffa Rahadya Atmawiguna (rahadya.daffaa@gmail.com)
Date	2025-12-28
Affected Asset	https://pegawai.my.id/employees
Severity	High
CVSS Score	8.1 CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N
Proof of Concepts	Please see Steps to Reproduce section

SUMMARY

Ditemukan kerentanan Broken Access Control yang signifikan pada endpoint /employees di situs pegawai.my.id. Pengguna dengan hak akses rendah dapat melakukan Force Browsing untuk mengakses halaman manajemen karyawan yang seharusnya dibatasi hanya untuk Administrator. Kerentanan ini memungkinkan pengguna biasa untuk melihat informasi sensitif seluruh staf, termasuk rincian gaji, alamat email, dan nomor telepon. Selain kebocoran data, pengguna juga dapat melakukan tindakan administratif seperti menambah karyawan baru atau mengedit data karyawan yang ada, termasuk memodifikasi status dan peran pengguna di antarmuka aplikasi. Penyerang bahkan dapat mengubah peran akun mereka sendiri menjadi Admin melalui fitur edit, meskipun mekanisme keamanan sesi pada *backend* kemudian memblokir akses masuk admin tersebut dengan menampilkan pesan kesalahan "403 | Unauthorized Action"

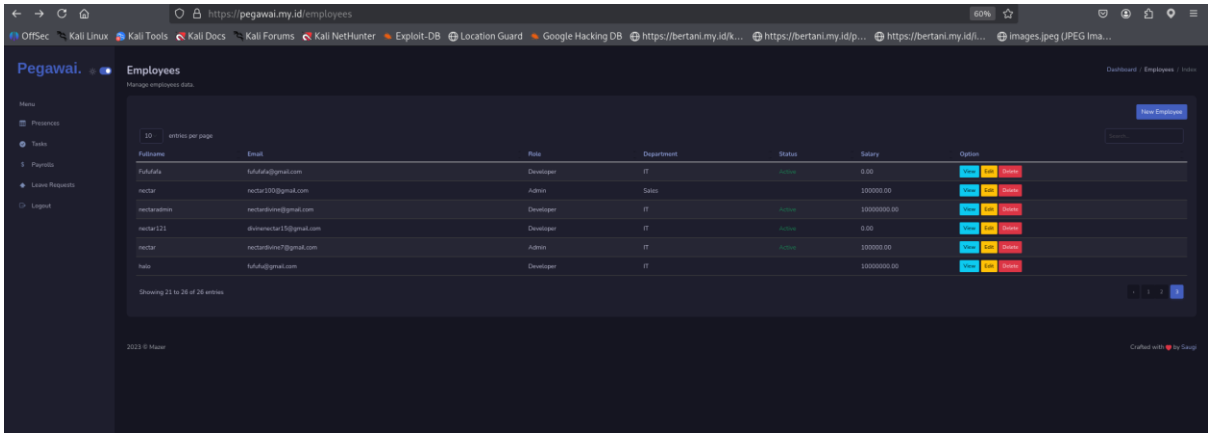
STEPS TO REPRODUCE

1. Login ke Akun anda sebagai user di URL https://pegawai.my.id/login

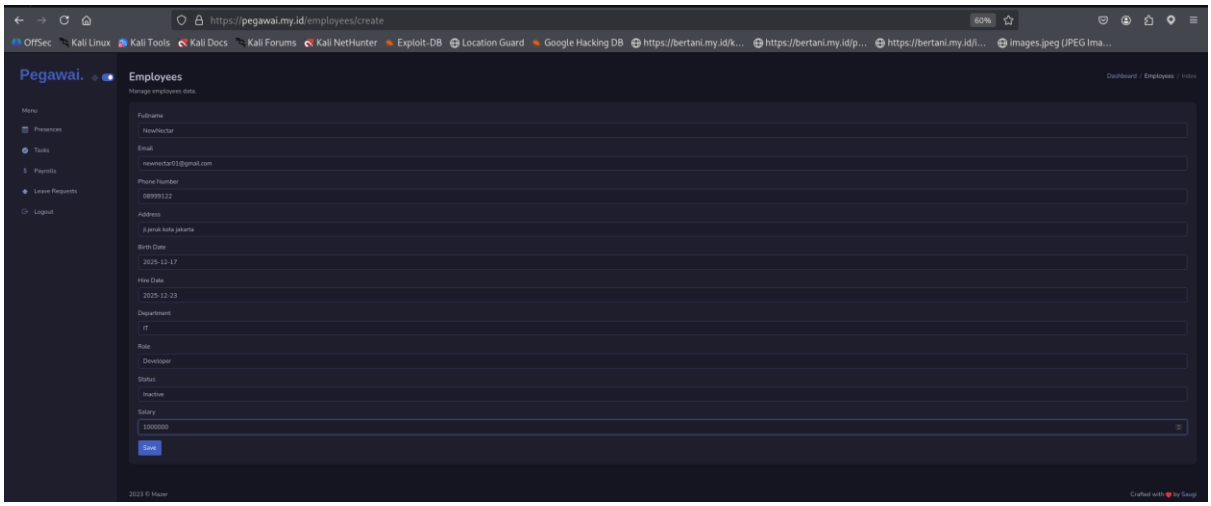
2. Jalankan perintah ini di cmd gobuster dir -u https://pegawai.my.id -w /usr/share/wordlists/dirb/common.txt -x .env,.env.bak,.env.old,.config.php,config.php.bak . Maka anda akan menemukan Alamat yang tidak ada di web yaitu /employees

```
Starting gobuster in directory enumeration mode
===============================================================
/.hta                 (Status: 403) [Size: 162]
/.hta.env.old         (Status: 403) [Size: 162]
/.hta.env.bak         (Status: 403) [Size: 162]
/.hta.env             (Status: 403) [Size: 162]
/.htaccess.config.php.bak (Status: 403) [Size: 162]
/.htaccess.env        (Status: 403) [Size: 162]
/.htaccess            (Status: 403) [Size: 162]
/.hta.config.php.bak  (Status: 403) [Size: 162]
/.htaccess.env.bak    (Status: 403) [Size: 162]
/.htaccess.env.old    (Status: 403) [Size: 162]
/.htpasswd.env.bak    (Status: 403) [Size: 162]
/.htpasswd.config.php.bak (Status: 403) [Size: 162]
/.htpasswd            (Status: 403) [Size: 162]
/.htpasswd.env        (Status: 403) [Size: 162]
/.htpasswd.env.old    (Status: 403) [Size: 162]
/build                (Status: 301) [Size: 178] [--> https://pegawai.my.id/build/]
/dashboard            (Status: 302) [Size: 354] [--> https://pegawai.my.id/login]
/departments          (Status: 302) [Size: 354] [--> https://pegawai.my.id/login]
/employees            (Status: 302) [Size: 354] [--> https://pegawai.my.id/login]
/favicon.ico          (Status: 200) [Size: 0]
/forgot-password      (Status: 200) [Size: 2862]
/index.php            (Status: 200) [Size: 37798]
/login                (Status: 200) [Size: 4060]
/logout               (Status: 302) [Size: 354] [--> https://pegawai.my.id/login]
/password             (Status: 405) [Size: 244848]
/profile              (Status: 302) [Size: 354] [--> https://pegawai.my.id/login]
/register             (Status: 200) [Size: 4574]
/robots.txt           (Status: 200) [Size: 24]
/roles                (Status: 302) [Size: 354] [--> https://pegawai.my.id/login]
/tasks                (Status: 302) [Size: 354] [--> https://pegawai.my.id/login]
/up                   (Status: 200) [Size: 1935]
Progress: 27678 / 27678 (100.00%)
===============================================================
Finished
===============================================================
```

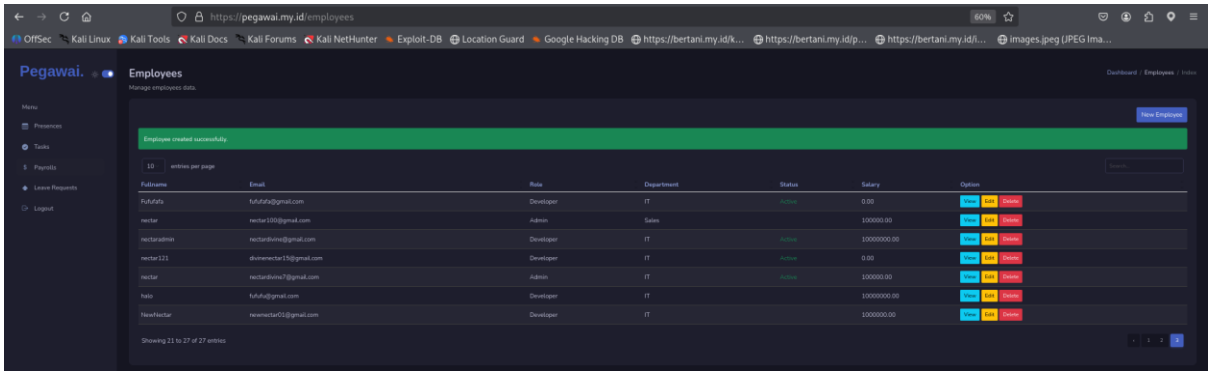
3. Masuk ke https://pegawai.my.id/employees



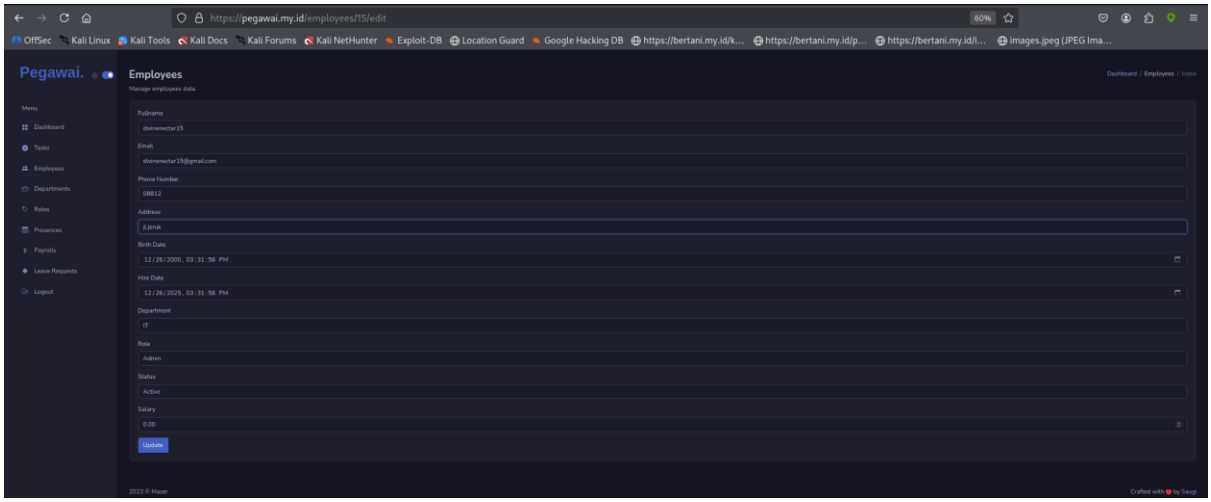
4. Lalu tekan new employees dan isi data yang diperlukan



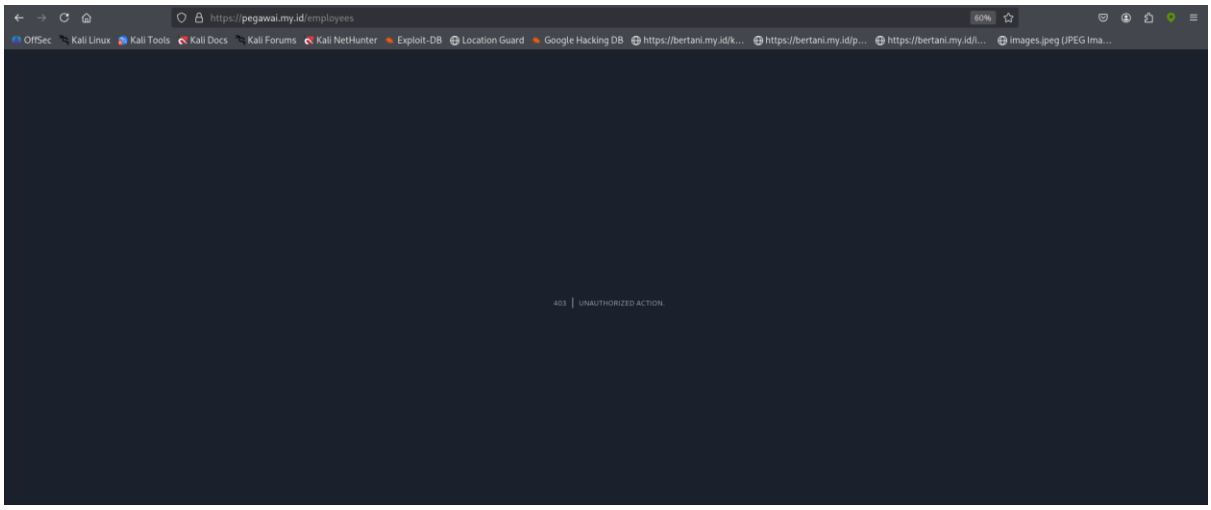
5. Maka anda bisa membuat user baru



6. Selain itu anda bisa mengubah role menjadi admin dengan cara edit akun anda dan isi phone number lalu addres dan ubah status menjadi active



7.Maka role admin berhasil di tambahkan tetapi anda tidak bisa login dengan admin karena akan muncul unauthrized action



EXPECTED RESULT

1. Akses ke endpoint administratif seperti /employees, /employees/create, dan /employees/{id}/edit harus ditolak secara tegas (HTTP 403 Forbidden) bagi pengguna non-administrator.
2. Informasi sensitif seperti kolom Salary (Gaji) tidak boleh dikirimkan ke browser pengguna jika mereka tidak memiliki otorisasi yang tepat.
3. ogika di sisi server (*Server-Side*) harus memvalidasi peran pengguna sebelum mengizinkan perubahan permanen pada atribut peran di database.

ACTUAL RESULT

1. Pengguna biasa dapat melewati batasan antarmuka dan mengakses halaman manajemen karyawan secara langsung melalui teknik *Force Browsing*.
2. Data sensitif seluruh staf, termasuk gaji dan informasi pribadi (PII), dapat dilihat dengan jelas oleh pengguna tidak berwenang.
3. Aplikasi mengizinkan pengguna untuk membuat karyawan baru atau mengedit data yang sudah ada.
4. Sistem memproses permintaan untuk mengubah peran pengguna menjadi Admin, namun ketika pengguna tersebut mencoba masuk ke panel admin, sistem mengeluarkan kesalahan 403 | Unauthorized Action.

IMPACT

1. Sensitive Data Exposure: Kebocoran informasi gaji dan data pribadi seluruh karyawan merupakan pelanggaran privasi serius yang merusak reputasi perusahaan.
2. Integrity Violation: Penyerang dapat memanipulasi database dengan menambah akun palsu atau mengubah data karyawan yang sah, sehingga mengganggu operasional departemen HR.
3. Policy & Input Validation Failure: Kemampuan untuk menandai akun sebagai "Admin" di tingkat database menunjukkan kegagalan validasi input dan otorisasi yang parah pada fungsi *update*, meskipun serangan eskalasi wewenang penuh tertahan oleh validasi sesi.

RECOMMENDATION

1. Implement Middleware: Terapkan *middleware* otorisasi yang ketat (misalnya IsAdmin) pada rute /employees dan semua sub-rute terkait untuk memastikan pengecekan peran dilakukan di setiap permintaan.
2. Server-Side Role Validation: Pastikan fungsi *Create* dan *Update* memverifikasi apakah pengguna yang melakukan permintaan memiliki otoritas administratif untuk mengubah data sensitif atau atribut peran.
3. Data Minimization: Jangan menyertakan informasi sensitif seperti gaji dalam respons HTML atau JSON jika pengguna yang meminta data tersebut bukan merupakan bagian Keuangan atau Administrator.

REFERENCES

1. OWASP Top 10 - A01:2021 Broken Access Control: https://owasp.org/Top10/A01_2021-Broken_Access_Control/